

Práctica 3 - Auditoría y Peritaje de Sistemas

Parte I: Conceptos Generales

1. Explique las razones principales para auditar sistemas y dar ejemplos de cada una.

Razones principales para auditar sistemas de información

- *Costos por pérdida de datos*
 - Los datos proveen a la organización de una "imagen" de sí misma, su entorno y su futuro. Si esa imagen se pierde o es inexacta, se generan grandes pérdidas.
 - *Ejemplos:*
 - Pérdida de cuentas corrientes de un banco.
 - Pérdida del historial académico de alumnos en una universidad.
- *Costos por decisiones incorrectas*
 - La calidad de las decisiones depende de:
 - La calidad de los datos (veraces, completos, oportunos).
 - La correctitud de las reglas de decisión implementadas en los sistemas.
 - *Ejemplos:*
 - Cálculo erróneo de amortización sobre un bien de poco valor.
 - Un error en el software de un sistema médico que administra dosis incorrectas a pacientes.
- *Costos por abusos computacionales*
 - Los abusos informáticos tienden a generar pérdidas mayores que los fraudes tradicionales. *Tipos de abuso:*
 - Hacking: Acceso no autorizado para modificar o robar datos. *Ejemplo:* Hackeo a la mayor plataforma de Bitcoin, con robo de 7.000 BTC.
 - Virus: Programas maliciosos que afectan operaciones o destruyen información. *Ejemplo:* Virus que atacan archivos del sistema o macros.
 - Acceso físico ilegal: Ingreso sin autorización a instalaciones físicas. *Ejemplo:* Robo físico de servidores con información crítica.
 - Abuso de privilegios: Uso indebido de accesos autorizados. *Ejemplo:* Copiar datos confidenciales a los que se tiene acceso legítimo.
- *Costos por errores de computación*
 - Errores en sistemas automáticos pueden ser graves, ya que:
 - Son determinísticos.
 - Se reproducen rápidamente.

- Son costosos de corregir.
- *Ejemplos:*
 - Un error en software de lanzamiento de misiles que genera un lanzamiento incorrecto.
 - Fallos en sistemas de cirugía asistida que afecten la vida del paciente.
- *Valor del hardware, software y personal*
 - Los recursos de TI son críticos para la operación de las organizaciones.
 - *Ejemplos:*
 - Datos: Si la competencia accede a información sensible, puede haber pérdida de ventajas estratégicas.
 - Hardware: Fallo en un servidor central.
 - Software: Pérdida de un sistema core sin respaldo.
 - Personal: Renuncia de un profesional clave sin transferencia de conocimiento.
- *Mantenimiento de la privacidad*
 - La automatización permite la integración de grandes volúmenes de datos personales. Esto puede violar derechos si no se audita adecuadamente.
 - *Ejemplo:*
 - Uso de datos genéticos de una persona por parte de aseguradoras para denegar cobertura.
- *Evolución controlada del uso de TI*
 - La confiabilidad de los sistemas complejos no está garantizada. Una adopción no controlada puede generar efectos perjudiciales.
 - *Ejemplos:*
 - Sistemas mal implementados que provocan estrés laboral.
 - Automatización sin capacitación que genera rechazo de los usuarios.

2. Para cada uno de los siguientes interesados, presente un ejemplo de cómo un mal procesamiento de información realizado por un sistema informático, puede conducir a una toma de decisiones incorrecta:

1. Gerente de una empresa vinculada a la industria automotriz
2. Funcionario de ARBA
3. Consejo Directivo de una facultad

Gerente de una empresa vinculada a la industria automotriz

- *Escenario:* El gerente debe decidir cuánto stock de autopartes importar para la próxima temporada.
- *Problema:* El sistema de información presenta datos desactualizados del inventario por un error de sincronización.

- *Consecuencia:* El gerente sobreestima la necesidad de stock e importa más piezas de las necesarias, incurriendo en costos de almacenamiento innecesarios y posible obsolescencia de productos.
- *Impacto:*
 - Pérdidas económicas.
 - Posibles recortes de personal o ajustes no planificados.

Funcionario de ARBA

- *Escenario:* El funcionario evalúa la situación fiscal de un contribuyente para iniciar una acción de inspección.
- *Problema:* El sistema de gestión impositiva no muestra ingresos por actividades exentas correctamente debido a un error en la parametrización de las categorías fiscales.
- *Consecuencia:* Se ordena una fiscalización incorrecta, generando molestias al contribuyente, desgaste institucional y utilización innecesaria de recursos públicos.
- *Impacto:*
 - Daño a la imagen de la entidad.
 - Ineficiencia operativa.
 - Potencial reclamo legal por parte del contribuyente afectado.

Consejo Directivo de una facultad

- *Escenario:* El Consejo evalúa el cierre de una carrera de grado por supuesta baja matrícula.
- *Problema:* El sistema de gestión académica no contabiliza correctamente a los alumnos que cursan materias de primer año pero que aún no han completado su inscripción definitiva.
- *Consecuencia:* Se decide cerrar la carrera sin tener una imagen completa de la demanda real.
- *Impacto:*
 - Pérdida de una oferta educativa valiosa.
 - Reclamos de alumnos y docentes.
 - Reputación afectada ante la comunidad académica.

3. ¿Qué tipo de abusos computacionales conoce? ¿Cuáles son las consecuencias de estos abusos?

Se explicaron en el punto 1. pero profundizamos. Los **abusos computacionales** son incidentes relacionados con el uso indebido o malicioso de tecnologías de la información, en los cuales una *víctima* sufre (o podría haber sufrido) una pérdida, y un *perpetrador* obtiene (o podría obtener) una ganancia intencional. **Tipos de Abusos:**

- *Hacking:* Acceso no autorizado a sistemas informáticos para leer, modificar, eliminar información o interrumpir servicios.

- *Virus*: Programas maliciosos que infectan archivos, sistemas o macros para dañar, interrumpir o controlar las operaciones del sistema.
- *Acceso físico ilegal*: Ingreso no autorizado a instalaciones físicas como salas de servidores o terminales de trabajo, con el fin de robar, manipular o destruir datos o equipos.
- *Abuso de privilegios*: Ingreso no autorizado a instalaciones físicas como salas de servidores o terminales de trabajo, con el fin de robar, manipular o destruir datos o equipos.
- *Abuso de privilegios*: Uso indebido de accesos o permisos legítimos para fines no autorizados.

Consecuencias de los abusos computacionales

- *Destrucción de activos*: Ej.: eliminación de bases de datos o daños físicos a equipos.
 - *Sustracción de activos*: Ej.: robo de información, software o equipos.
 - *Modificación de activos*: Ej.: alteración de registros contables o transacciones.
 - *Violación de privacidad*: Ej.: filtración de datos personales o confidenciales.
 - *Interrupción de operaciones*: Ej.: caída de sistemas críticos o servicios públicos.
 - *Uso no autorizado de activos*: Ej.: utilización de licencias de software o servidores sin permiso.
 - *Daño físico a personas*: Ej.: si el abuso compromete sistemas de salud, transporte o energía.
4. Explique al menos dos características que diferencien entre un abuso informático y otro tipo de fraude comercial.

Características clave que diferencian a un abuso informático de un fraude comercial tradicional

- *Medio a través del cual se comete el hecho*
 - Abuso informático:
 - El delito se comete utilizando tecnologías de la información, como computadoras, redes, sistemas operativos o software.
 - Fraude comercial tradicional:
 - Se realiza generalmente en forma manual o física, sin uso sustancial de tecnologías informáticas.
- *Escalabilidad y velocidad del daño*
 - Abuso informático:
 - Puede ejecutarse a gran escala y con rapidez, afectando grandes volúmenes de información o activos en cuestión de segundos.
 - Fraude comercial tradicional:
 - Generalmente tiene alcance más limitado y progresivo, ya que requiere interacción humana y ocurre a un ritmo más lento.

- *Trazabilidad*
 - El abuso informático puede dejar rastros en logs digitales (aunque difíciles de detectar o interpretar), mientras que el fraude tradicional puede depender de documentos físicos que se pierden o destruyen.
- *Perfil del perpetrador*
 - En abusos informáticos, se requieren conocimientos técnicos, lo que implica un perfil más especializado. En fraudes tradicionales, el conocimiento técnico puede no ser necesario.

5. Describa con sus palabras que entiende por auditoría de sistemas de información.

La auditoría de sistemas de información es un **proceso sistemático y planificado** mediante el cual se **recolecta, analiza y evalúa evidencia** sobre los sistemas informáticos de una organización. El objetivo principal es verificar si dichos sistemas:

- *Protegen adecuadamente los activos* (hardware, software, datos, personal).
- *Mantienen la integridad de los datos*, es decir, que sean correctos, completos, veraces y consistentes.
- *Permiten alcanzar los objetivos organizacionales con efectividad*, asegurando que los sistemas cumplan con lo que se espera de ellos.
- *Usan los recursos con eficiencia*, es decir, que no desperdicien tiempo, dinero o capacidad tecnológica.

6. Explique los cuatro objetivos de la auditoría de sistemas de información.

Explicados en el 5. pero profundizamos. Los cuatro objetivos principales de la auditoría de sistemas de información son:

- *Preservar los activos*
 - La auditoría busca garantizar que los activos relacionados con los sistemas de información estén protegidos contra pérdidas, robos, abusos o destrucción. Incluye: Hardware, Software, Datos, Personal, etc.
- *Mantener la integridad de los datos*
 - Se refiere a asegurar que los datos sean:
 - Correctos.
 - Completos.
 - Consistentes.
 - Veraces.
 - Sin integridad, los datos no reflejan la realidad de la organización y pueden llevar a decisiones equivocadas, fraudes o pérdidas de competitividad.

- *Alcanzar los objetivos organizacionales con eficacia*
 - Un sistema de información debe cumplir con los objetivos para los que fue diseñado, facilitando que la organización logre sus metas. Esto implica:
 - Que responda a las necesidades de los usuarios.
 - Que esté alineado con los procesos del negocio.
 - Que permita tomar decisiones oportunas y acertadas.
- *Usar los recursos con eficiencia*
 - La auditoría también verifica que los recursos tecnológicos y humanos se estén utilizando de forma óptima, sin desperdicios innecesarios.

7. ¿Qué significa que la alta gerencia implemente un sistema de control interno? ¿Cómo se lleva a cabo?

Que **la alta gerencia implemente un sistema de control interno** significa que la alta dirección de la organización **asume la responsabilidad de establecer mecanismos formales y organizados** para:

- *Proteger los activos*
- *Garantizar la integridad y precisión de los datos*
- *Asegurar el cumplimiento de los objetivos institucionales*
- *Detectar, prevenir y corregir errores o fraudes*

Es una forma de establecer reglas, procedimientos y estructuras que permiten **controlar y supervisar** el uso de los recursos de tecnología de la información. **Es importante que lo implemente la alta gerencia porque:**

- Da legitimidad a los controles.
- Permite asignar recursos y presupuesto.
- Establece una cultura organizacional de responsabilidad y transparencia.
- Sin compromiso de la alta dirección, los controles internos son débiles o simbólicos.

¿Cómo se lleva a cabo?

La implementación del control interno se realiza a través de **componentes estructurados**, que deben ser definidos, comunicados y aplicados dentro de la organización, **estos componentes son:**

- *Separación de obligaciones:* Evitar que una misma persona pueda iniciar, registrar y autorizar una transacción.
- *Delegación clara de autoridad y responsabilidad:* Establecer roles y responsabilidades bien definidos.
- *Reclutamiento y capacitación de personal calificado:* Asegurar que quienes trabajan en los sistemas estén capacitados técnica y éticamente.

- *Sistema de autorizaciones:* Incluir autorizaciones generales (políticas) y específicas (transacciones individuales).
- *Documentos y registros adecuados:* Mantener trazabilidad de todas las transacciones importantes, incluso en sistemas automatizados.
- *Controles físicos y documentación de activos:* Proteger físicamente el acceso a servidores, equipos y datos.
- *Chequeos independientes de performance:* Revisar el funcionamiento y rendimiento de los sistemas por terceros o áreas independientes.
- *Comparación periódica de activos con registros:* Verificar que los datos del sistema coincidan con la realidad.

Parte II: Controles y riesgos de Auditoría

8. Explique por qué un control en un sistema de información es un sistema.

Un control en un sistema de información es un sistema en sí mismo porque no se trata de un único elemento aislado, sino de **un conjunto coordinado de componentes y procesos** que tienen como objetivo **prevenir, detectar o corregir eventos ilegales**. Las **razones principales** son:

- Tiene componentes interrelacionados.
 - Cumple una función clara: mitigar riesgos.
 - Opera en un entorno dinámico y debe adaptarse a nuevas amenazas.
 - Su efectividad se basa en la coordinación de varios mecanismos.
- Este enfoque sistémico permite **evaluar su confiabilidad, identificar debilidades y garantizar que cumple realmente con su propósito dentro del marco de la auditoría**.

9. Explique las diferencias entre un control preventivo, control detectivo, y control correctivo. Provea ejemplos para cada tipo de control.

Control Preventivo

- Controles que evitan que ocurra un evento ilegal o no deseado. Se aplican antes de que se produzca una actividad crítica.
- *Objetivo*
 - Reducir la probabilidad de que ocurra un error, fraude o evento no autorizado.
- *Ejemplos*
 - Instrucciones claras y obligatorias para llenar un formulario (aunque el instructivo no es en sí un control, puede formar parte de uno).
 - Roles y permisos predefinidos en un sistema para que solo personal autorizado acceda a determinadas funciones.

- Validación de campos obligatorios en formularios web.
- Firewall configurado para bloquear tráfico sospechoso.

Control Detectivo

- Son controles que permiten identificar que un evento ilegal o no deseado ha ocurrido.
- *Objetivo*
 - Descubrir errores, fraudes o eventos no autorizados después de que ocurrieron.
- *Ejemplos*
 - Programa que valida datos de entrada y rechaza valores incorrectos.
 - Logs de acceso al sistema revisados periódicamente.
 - Alarmas de detección de intrusión (IDS).
 - Revisión de conciliaciones bancarias.

Control Correctivo

- Son controles que corrigen los efectos de un evento no deseado después de que ha sido detectado.
- *Objetivo*
 - Minimizar el impacto de los errores o eventos ilegales y restaurar el estado correcto del sistema.
- *Ejemplos*
 - Sistema que detecta ruido en la transmisión de datos y permite retransmitir paquetes corruptos.
 - Restauración desde un backup ante pérdida de datos.
 - Parcheo de seguridad después de detectar una vulnerabilidad.
 - Reset automático de contraseñas ante intentos múltiples de login fallido.

Tipo de Control	Cuándo actúa	Qué hace
Preventivo	Antes del evento	Evita que ocurra
Detectivo	Después del evento	Identifica que ocurrió
Correctivo	Después del evento	Corrige o mitiga el impacto

10. ¿Cuál es la tarea del auditor en cuanto a los controles?

La **tarea principal del auditor** es **evaluar si los controles están adecuadamente ubicados y si funcionan correctamente** para:

- *Prevenir* eventos ilegales o no deseados.

- *Detectar* estos eventos en caso de que ocurran.
- *Corregir* sus efectos para minimizar pérdidas.

El auditor debe seguir un proceso sistemático que incluye:

- *Identificación de controles existentes*
 - Analiza el sistema y los procesos.
 - Determina qué controles están implementados (tanto gerenciales como de aplicación).
- *Evaluación de su confiabilidad*
 - Verifica si cada control cubre los eventos relevantes.
 - Estima cuán confiables son los controles (efectividad, cobertura, posibilidad de falla).
- *Recolección de evidencia*
 - Realiza pruebas (walk-throughs, inspecciones, entrevistas, análisis de logs).
 - Evalúa si los controles funcionan en la práctica y no solo en el papel.
- *Detección de brechas*
 - Identifica controles ausentes, débiles o ineficientes.
 - Determina el nivel de exposición a riesgos.

11. Explique desde el punto de vista de auditoría de sistemas de información el concepto de "factorizar en subsistemas" y qué criterio(s) se aplica(n) para factorizar un sistema en subsistemas.

Desde el punto de vista de la **auditoría de sistemas de información**, **factorizar** un sistema significa:

- **Dividir un sistema complejo en componentes lógicos más pequeños (subsistemas), cada uno con funciones específicas**, para facilitar su comprensión, evaluación y auditoría. Esta técnica permite al auditor **enfocar su análisis** en partes manejables del sistema, lo cual es especialmente útil en entornos grandes y heterogéneos. **Factorizamos por las siguientes razones:**
- **Identificar controles relevantes** por subsistema.
- **Evaluar la confiabilidad de cada parte**, y así estimar la confiabilidad global.
- **Asignar responsabilidades** y priorizar esfuerzos de auditoría.

Criterios para factorizar un sistema

- *Por función*
 - El auditor identifica primero las funciones principales del sistema y luego divide el sistema de acuerdo a esas funciones.
- *Acoplamiento y cohesión*

- Acoplamiento bajo: los subsistemas deben ser independientes entre sí en lo posible, lo que facilita su análisis individual.
- Alta cohesión: cada subsistema debe estar orientado a una sola función clara, sin mezclar responsabilidades.
- *Por tipo de funciones*
 - Se distinguen dos grandes grupos de subsistemas:
 - *Funciones gerenciales*
 - *Funciones de aplicación*

12. Indique qué otros criterios de factorización existen.

Especificados arriba pero profundizamos. Además de las funciones, existen otras dos guías:

- *Acoplamiento y cohesión*
 - Acoplamiento bajo: los subsistemas deben ser independientes entre sí en lo posible, lo que facilita su análisis individual.
 - Alta cohesión: cada subsistema debe estar orientado a una sola función clara, sin mezclar responsabilidades.
- *Por tipo de funciones*
 - Se distinguen dos grandes grupos de subsistemas:
 - *Funciones gerenciales*
 - Las funciones que se deben realizar para asegurar que el desarrollo, la implementación, operación y mantenimiento de los sistemas de información proceden de una forma planificada y controlada.
 - *Funciones de aplicación*
 - Tareas que son necesarias ejecutar para realizar un procesamiento de información confiable. Relacionado con "ciclos".

En base a las funciones gerenciales

Subsistema Gerencial	Descripción
Alta Gerencia	Debe asegurar que las funciones de los SI estén bien administradas. Decisiones de políticas a largo plazo de cómo serán usados los SI.
Gerencia de Sistemas de Información	Responsabilidad general de planificar y controlar todas las actividades de los SI. Aconseja a la alta gerencia de las decisiones políticas de largo plazo y las traduce en metas y objetivos de corto plazo.
Gerencia de Desarrollo de Sistemas	Responsable del diseño, implementación y mantenimiento de los sistemas.

Subsistema Gerencial	Descripción
Gerencia de Programación	Responsable de la programación de nuevos sistemas, mantenimiento de los viejos y soporte general.
Administración de Datos	Responsable de lograr los objetivos de planificación y control en relación al uso de los datos de la organización.
Gerencia de Aseguramiento de Calidad	Responsable de asegurar que el desarrollo, operación y mantenimiento de los sistemas es conforme a los estándares de calidad establecidos.
Administración de Seguridad	Responsable por los controles de acceso y seguridad física de las funciones de los SI.
Gerencia de Operaciones	Responsable de la planificación y control de las operaciones diarias.

En base a las funciones de aplicación

- Los sistemas de información que soportan una organización, se dividen en ciclos. Los ciclos varían de acuerdo al tipo de organización. Cada ciclo es factorizado en uno o más sistemas de aplicación. El conjunto de subsistemas de aplicación incluyen lo siguiente:

Subsistema de Aplicación	Descripción
Lmítrofe	Componentes que establecen las interfaces entre el usuario y el sistema.
Input	Componentes que capturan, preparan e ingresan comandos y datos al sistema.
Comunicaciones	Componentes que transmiten datos entre los subsistemas y sistemas.
Procesamiento	Componentes que realizan toma de decisiones, cálculos, clasificación, ordenamiento y sumariación de datos dentro del sistema.
Base de Datos	Componentes que definen, agregan, acceden, modifican o eliminan datos.
Ooutput	Componentes que buscan y presentan los datos al usuario.

13. ¿De qué manera se mide la confiabilidad de los controles?

La **confiabilidad** se refiere a la **efectividad real del control** para prevenir, detectar o corregir eventos ilegales o no deseados. No basta con que el control exista; debe **funcionar correctamente y de forma consistente** ante los eventos que pretende mitigar. Medimos la **confiabilidad de los controles**:

- *Identificando eventos y transacciones relevantes*
 - El análisis comienza desde las funciones clave del sistema para entender qué debería y qué no debería pasar.
 - ¿Qué tipo de eventos podrían surgir en el subsistema?
 - ¿Son legales o ilegales?
 - ¿Qué transacciones pueden generarlos?
- *Evaluando cómo los controles responden ante esos eventos*
 - Para cada evento ilegal identificado, se debe evaluar:
 - ¿Existe un control que lo mitigue?
 - ¿Está ubicado correctamente en el flujo del proceso?
 - ¿Actúa de forma preventiva, detectiva o correctiva?
 - ¿Es automático o manual?
 - ¿Es consistente ante múltiples escenarios?
- *Analizando evidencia de funcionamiento*
 - Los auditores usan técnicas como:
 - Walk-throughs: seguir una transacción paso a paso en el sistema.
 - Revisión de logs: evidencia de ejecución de controles.
 - Pruebas de cumplimiento: ejecutar escenarios simulados.
 - Entrevistas con responsables del proceso.
- *Estimando el nivel de confiabilidad*
 - Aunque no siempre se cuantifica numéricamente, se puede clasificar según escalas:

Nivel	Descripción
Alta (A)	El control cubre completamente el evento y funciona con consistencia
Media (M)	El control existe pero no es completamente eficaz o tiene limitaciones
Baja (B)	El control es débil, incompleto o no se aplica de manera confiable

- *Analizando el impacto en el nivel superior*
 - Una vez evaluados los controles de subsistemas de menor nivel, se estima su impacto en los subsistemas superiores, considerando:
 - Frecuencia del evento
 - Impacto económico o reputacional
 - Potencial de fraude o pérdida

14. Identifique cuatro tipos de riesgos. Explique la naturaleza de cada uno de ellos.

El concepto de **riesgo** se analiza como parte de la fórmula $RDA = RI \cdot RC \cdot RD$. Esta expresión refleja cómo los distintos tipos de riesgos interactúan y deben ser gestionados para mantener un nivel aceptable de confianza en el sistema auditado.

- *RDA*: Riesgo Deseado de Auditoría.
- *RI*: Riesgo Inherente.
- *RC*: Riesgo de Control.
- *RD*: Riesgo de Detección.

Tipos de Riesgos

- *Riesgo Deseado de Auditoría*
 - *Naturaleza*: Es el nivel máximo de riesgo que el auditor está dispuesto a aceptar, considerando las consecuencias de no detectar errores o irregularidades materiales.
 - No se calcula, se decide en función del entorno, la criticidad del sistema y el impacto potencial.
- *Riesgo Inherente*
 - *Naturaleza*: Es el riesgo de que ocurran errores materiales o irregularidades sin considerar aún los controles existentes. Depende de:
 - Naturaleza del sistema (por ejemplo, facturación o producción).
 - Entorno de negocio (industria cambiante, entorno competitivo).
 - Complejidad del proceso o tecnología.
- *Riesgo de Control*
 - *Naturaleza*: Es el riesgo de que los controles internos no funcionen adecuadamente para prevenir o detectar errores o eventos ilegales. Depende de:
 - Existencia y ubicación de los controles
 - Su funcionamiento efectivo y consistente
- *Riesgo de Detección*
 - *Naturaleza*: Es el riesgo de que los procedimientos de auditoría no logren detectar errores materiales o fraudes, aunque existan. Depende de:
 - Calidad y profundidad de los procedimientos
 - Habilidad del auditor para interpretar evidencia

Parte III: Proceso de Auditoría

15. Explique brevemente el proceso de auditoría.

El **proceso de auditoría de sistemas de información** consiste en las siguientes etapas:

- *Planificación*

- Primera etapa del proceso.
- Varía si es una auditoría interna o externa:
 - Interna: se enfoca en pérdidas por ineficiencias o ineficacias operativas.
 - Externa: se enfoca en errores en los estados financieros.
- Tareas principales:
 - Determinar el alcance de la auditoría.
 - Emitir opiniones sobre los riesgos (RDA, RI, RC).
 - Calcular el Riesgo de Detección (RD) necesario.
 - Recolectar y documentar evidencias.
- *Ejecución de pruebas y procedimientos*
 - Se aplican distintos tipos de procedimientos según el objetivo:
 - Comprender los controles internos.
 - Testeo de controles (gerenciales y de aplicación).
 - Testeos sustantivos (detalle de transacciones y balances contables).
 - Procedimientos de revisión analítica.
 - Se evalúa la efectividad y eficiencia de los sistemas y se estiman posibles pérdidas.
- *Evaluación y Conclusión*
 - Se realiza una evaluación final sobre la confiabilidad de los controles y los riesgos.
 - Se puede ajustar la profundidad de las pruebas según la fortaleza o debilidad de los controles detectados.
 - Se completan los testeos necesarios para emitir un juicio fundamentado.
- *Elaboración del Informe*
 - El informe incluye:
 - Objetivos y enfoque de la auditoría.
 - Conclusiones críticas.
 - Recomendaciones.
 - Evidencia que respalda las conclusiones.
 - Se emite una opinión de auditoría (sin calificación, con calificación, adversa o excusada) según los hallazgos.

16. Enuncie cinco tipos de procedimientos de auditoría que pueden ser usados para recolectar evidencia en una auditoría.

Los **cinco tipos de procedimientos de auditoría** utilizados para **recolectar evidencia** son los siguientes:

- *Procedimientos para comprender los controles*
 - Sirven para verificar si los controles existen, cómo están diseñados y si funcionan.

- Técnicas: cuestionarios, inspecciones, observaciones.
- *Testeo de controles*
 - Evalúan si los controles operan eficazmente.
 - Técnicas: cuestionarios, inspecciones, observaciones, reprocesamiento de datos.
- *Testeos sustantivos de detalle de transacciones*
 - Detectan errores monetarios o irregularidades en transacciones que afectan los estados financieros.
 - Ejemplo: control de facturación.
- *Testeos sustantivos de detalle de balances contables*
 - Se enfocan en los registros contables finales.
 - Ejemplo: confirmar con clientes si los saldos registrados son correctos (circularización).
- *Procedimientos de revisión analítica*
 - Analizan las relaciones entre ítems de datos para detectar áreas inusuales.
 - Ejemplo: comparar ingresos por ventas entre distintos períodos.

17. Enumere tres tipos de testeos que se pueden realizar durante una auditoría.

Durante una **auditoría de sistemas de información** se pueden realizar varios **tipos de testeos** como:

- *Testeo de Controles*
 - Evalúa si los controles internos (gerenciales y de aplicación) funcionan eficazmente.
 - Permite reducir el alcance de otros testeos si los controles son confiables.
- *Testeo de transacciones*
 - Analiza si existen errores o irregularidades en el procesamiento de transacciones individuales.
 - También permite evaluar la eficacia y eficiencia operativa.
 - Ejemplo: revisión de cálculos, precios o consultas a base de datos.
- *Testeo de resultados generales (balances contables)*
 - Se realiza para emitir un juicio sobre las pérdidas potenciales si el sistema falla en proteger activos o asegurar integridad de los datos.
 - Son los más costosos de realizar.
 - Ejemplos: control de inventario físico, recálculo de amortizaciones, confirmaciones con terceros.

18. ¿Cómo se lleva a cabo la planificación de una auditoría? Cite diferencias entre auditoría interna y externa.

Durante la etapa de **planificación** se realizan varias **tareas claves** como:

- *Determinar el alcance* de la auditoría (sistema, conjunto de sistemas o área de TI).
- *Emitir opiniones* sobre los riesgos:
 - *RDA* (Riesgo Deseado de Auditoría),
 - *RI* (Riesgo Inherente),
 - *RC* (Riesgo de Control).
- *Calcular el RD* (Riesgo de Detección) necesario para cumplir con el *RDA*.
- *Recolectar evidencia preliminar*, por ejemplo:
 - entrevistas,
 - revisión de documentación,
 - observación directa.
- *Documentar la evidencia* usando herramientas como diagramas de flujo, cuestionarios o narrativas.

Diferencias entre auditoría interna y externa durante la planificación

Aspecto	Auditoría Interna	Auditoría Externa
Objetivo principal	Evaluar eficiencia e <i>ineficiencias operativas</i>	Evaluar errores en los <i>estados financieros</i>
Enfoque	Se enfoca en los procesos internos y su impacto operativo	Se enfoca en la exactitud y validez de la información contable presentada
Tareas de planificación	- Asignar personal adecuado - Obtener info del cliente - Identificar áreas de riesgo - Comprender el negocio mediante revisión analítica	- Investigar nuevos clientes - Obtener contrato - Realizar revisión analítica - Identificar riesgos financieros
Relación con la organización	Empleado interno o parte de la estructura organizativa	Profesional externo contratado

19. Describa el contenido de un informe de auditoría.

Un *informe de auditoría de sistemas de información* debe ser claro, estructurado y bien fundamentado, normalmente contiene:

- *Introducción*
 - Describe los objetivos de la auditoría, es decir, qué se auditó y por qué.
 - Define el alcance del trabajo realizado (sistemas, áreas, períodos).
- *Enfoque general utilizado*
 - Explica la metodología aplicada, incluyendo los procedimientos, técnicas y criterios de evaluación.

- *Resumen de conclusiones críticas*
 - Enumera los hallazgos relevantes, tales como deficiencias en los controles, irregularidades, o riesgos detectados.
 - Describe el grado de impacto de cada hallazgo.
- *Recomendaciones*
 - Proporciona acciones correctivas o preventivas para mitigar los riesgos encontrados o mejorar la eficiencia del sistema.
- *Datos que respaldan las conclusiones*
 - Incluye la evidencia recolectada (documentación, entrevistas, observaciones, pruebas).
 - Sirve como sustento técnico y fáctico de las conclusiones del auditor.
- *Opinión de auditoría*
 - El informe puede poseer una Opinión de auditoría que puede ser: Sin calificación, Con calificación, Adversa o Excusada.

20. Describa los cuatro tipos de opinión que un auditor puede emitir.

Tipos de opinión

- *Excusada:* En base al trabajo realizado no se puede emitir opinión.
- *Adversa:* Se concluye que han ocurrido pérdidas materiales o que los estados financieros están distorsionados.
- *Con calificación:* Se concluye que han ocurrido pérdidas materiales o existen registros incorrectos, pero las cantidades no son considerables.
- *Sin calificación:* El auditor considera que no han ocurrido pérdidas materiales o no existen registros incorrectos.

Parte IV: Gobernanza de TI

21. Explique el significado del concepto "Gobernanza de TI".

La **Gobernanza de Tecnologías de la Información (TI)** es un subconjunto del **Gobierno Corporativo** que se enfoca específicamente en los sistemas de TI, su desempeño y los riesgos asociados a su uso. Se ocupa de **la relación entre la estrategia empresarial y la gestión de TI**, promoviendo que las decisiones estratégicas relacionadas con TI sean tomadas al más alto nivel de la organización, como una **junta directiva corporativa**.

Tiene como objetivo **asegurar que las inversiones en TI generen valor** para la organización y que los **riesgos relacionados con la tecnología sean mitigados adecuadamente**.

Según el Instituto de Gobernanza de TI, se define como el **conjunto de estructuras y procesos de liderazgo y organizativos** que aseguran que las TI **sostienen y extienden las estrategias y**

objetivos de la organización.

22. Explique qué es COBIT y cuáles son sus elementos.

COBIT (Control Objectives for Information and Related Technologies) es un marco de referencia creado por ISACA que proporciona un **conjunto de recursos, principios y buenas prácticas** para ayudar a las organizaciones a **adoptar una gobernanza y control efectivos de las TI**.

COBIT busca asegurar que **las TI generen valor, gestionen los riesgos y utilicen los recursos de manera eficiente**, contribuyendo directamente a los objetivos estratégicos de la organización. Para ello, establece una **diferenciación clara entre Gobernanza y Administración**:

- La **Gobernanza** evalúa, dirige y monitorea.
- La **Administración** planifica, construye, ejecuta y monitorea.

Elementos de COBIT:

- *Procesos de TI*
 - Clasificados en dos grandes dominios:
 - Gobernanza (EDM): Evalúa, Dirige y Monitorea.
 - Administración: Se subdivide en cuatro dominios:
 - APO: Alinear, Planear y Organizar
 - BAI: Construir, Adquirir e Implementar
 - DSS: Entregar, Servicio y Soporte
 - MEA: Monitorear y Evaluar
- *Objetivos de Control*
 - Son declaraciones del propósito a alcanzar mediante la implementación de controles en cada proceso de TI. Incluyen tanto objetivos de alto nivel como objetivos detallados.
- *Prácticas de Control*
 - Proveen el "qué", "cómo" y "por qué" implementar los controles. Son esenciales para guiar a gestores, auditores y usuarios en la ejecución de controles específicos.
- *Guías de Auditoría*
 - Orientan sobre cómo auditar los procesos de TI, incluyendo entrevistas, revisión documental y evaluación de riesgos de control.
- *Guías de Administración*
 - Incluyen modelos de madurez, factores críticos de éxito (CSF), indicadores clave de metas (KGI) e indicadores clave de desempeño (KPI), facilitando la gestión, evaluación y mejora continua de cada proceso.

23. Explique la diferencia entre Gobernanza y Administración de TI.

Gobernanza de TI se refiere a **quién toma las decisiones** importantes en materia de tecnologías de la información. Define **la autoridad, responsabilidad y rendición de cuentas** en la toma de decisiones estratégicas. Su objetivo es **asegurar que las TI generen valor, se alineen con los objetivos del negocio y gestionen riesgos adecuadamente**.

Administración de TI, en cambio, se enfoca en **la ejecución de esas decisiones**. Implica la **planificación, construcción, ejecución y monitoreo** de las actividades de TI siguiendo la dirección establecida por la gobernanza.

24. ¿Cuáles son los principios de COBIT?

Principios:

- *Satisfacer las necesidades de las partes interesadas*
 - COBIT busca crear valor para las partes interesadas mediante la obtención de beneficios, la optimización de recursos y la gestión adecuada de riesgos.
- *Cubrir la empresa de extremo a extremo*
 - La gobernanza de TI no se limita al área de sistemas, sino que abarca toda la organización, considerando tanto recursos internos como externos.
- *Aplicar un marco integrado*
 - COBIT se alinea e integra con otros estándares y buenas prácticas (como ITIL, TOGAF, ISO 27001), sirviendo como marco general para la gobernanza y administración de TI empresarial.
- *Habilitar un enfoque holístico*
 - COBIT define y considera siete habilitadores que interactúan entre sí:
 - Principios, políticas y marcos
 - Procesos
 - Estructuras organizacionales
 - Cultura, ética y comportamiento
 - Información
 - Servicios, infraestructura y aplicaciones
 - Personas, habilidades y aptitudes
- *Separar las funciones de gobernanza y administración*
 - COBIT distingue claramente entre:
 - Gobernanza: evalúa, dirige y monitorea
 - Administración: planifica, construye, ejecuta y evalúa las actividades en función de las directivas de gobernanza

25. Indique de qué forma organiza COBIT los procesos de TI.

COBIT organiza los procesos de TI en **dos grandes dominios: Gobernanza y Administración**, cada uno con su propia función y conjunto de procesos:

- **Gobernanza de TI (EDM)**
 - Se centra en evaluar, dirigir y monitorear (EDM: Evaluate, Direct, Monitor). Incluye 5 procesos clave:
 - EDM01: Asegurar el marco de gobernanza
 - EDM02: Asegurar la entrega de beneficios
 - EDM03: Asegurar la optimización de riesgos
 - EDM04: Asegurar la optimización de recursos
 - EDM05: Asegurar la transparencia para las partes interesadas
- **Administración de TI**
 - Se encarga de planificar, construir, ejecutar y monitorear en línea con la estrategia definida. Se divide en 4 dominios con un total de 32 procesos:
 - APO (13 procesos). Ej.: Gestión de estrategia, arquitectura, riesgos, seguridad.
 - BAI (10 procesos). Ej.: Gestión de proyectos, cambios, activos, configuración.
 - DSS (6 procesos). Ej.: Gestión de operaciones, incidentes, continuidad, seguridad.
 - MEA (3 procesos). Ej.: Evaluación del desempeño, controles internos y cumplimiento.

26. Explique cómo COBIT clasifica la administración de TI.

COBIT clasifica la **Administración de TI** en **cuatro dominios**, que representan las diferentes etapas del ciclo de vida de los servicios y soluciones de TI. Cada dominio agrupa procesos específicos que permiten planificar, construir, entregar y monitorear las soluciones de TI de manera eficaz y alineada con los objetivos del negocio:

- **APO – Alinear, Planear y Organizar**
 - Este dominio abarca la estrategia y la estructura organizacional. Se enfoca en cómo TI puede contribuir al logro de los objetivos de negocio.
- **BAI – Construir, Adquirir e Implementar**
 - Se refiere a la identificación, adquisición, desarrollo, implementación y mantenimiento de soluciones de TI.
- **DSS – Entregar, Servicio y Soporte**
 - Trata sobre la entrega efectiva de servicios de TI, asegurando operaciones estables y seguras, así como soporte a los usuarios.
- **MEA – Monitorear y Evaluar**
 - Se enfoca en la evaluación continua del desempeño, cumplimiento y control interno.

27. Justifique la importancia de aplicar COBIT en una organización.

Aplicar **COBIT** en una organización es importante porque permite establecer un **marco estructurado y alineado con las mejores prácticas internacionales** para la **gobernanza y gestión de TI**, asegurando que las tecnologías de la información realmente contribuyan al logro de los **objetivos estratégicos del negocio**.